

## Inhaltsverzeichnis

### Anleitung: Ransomware – Vorsorge und Wiederherstellung (linux1/linux0/linux7)

**Für:** Gerald Schade (Admin). Kein Dokument für die MFA – bei akutem Verdacht auf Ransomware zuerst Kontakt gemäß eigenem Eskalationsweg, dann diese Anleitung.

**Stand:** 2026-07-12, im Lauf des Tages aktualisiert (u. a. nach Praxistest der Mail-Alarmierung, s. Teil A.6). Bezieht sich auf die aktuelle Infrastruktur: linux1 (Produktiv), linux0/linux7 (Reserve/Failover über uebernahme.sh/rueckgabe.sh), Online-Backups über bulinux.sh/bumo.sh/bunacht.sh (mit Schutzdatei-Mechanismus, s. Teil A.6) sowie gsbackup.sh/dorsync.sh/7zdb.sh (ältere/ergänzende Skripte), tägliche Offline-Sicherung auf rotierende USB-Sticks über mokopr.ps1/morueck.ps1 (s. Teil A.1).

---

### Wichtiger Ausgangspunkt: Failover ≠ Ransomware-Schutz

Die bestehende linux0/linux7-Übernahme-Logik löst **Hardware-/Systemausfall**, nicht **Verschlüsselung durch Ransomware**. Wenn ein Verschlüsselungstrojaner sich im Netz ausbreitet (typischer Weg: über SMB/CIFS-Freigaben, offene RDP/SSH-Zugänge, oder ein infiziertes Windows-Client-System, das auf die Server-Freigaben zugreift), wären linux0/linux7 potenziell **genauso betroffen**, sofern sie zum Zeitpunkt der Infektion im Netz erreichbar wären und deren Freigaben beschreibbar wären.

**Korrektur/Ergänzung (Stand 12.7.2026, nach genauerer Durchsicht):** Diese Gefahr ist in der Praxis kleiner als hier ursprünglich angenommen, aus zwei Gründen, die schon vorher bestanden:

- Samba läuft auf linux0/linux7 **im Normalbetrieb bewusst nicht** (nur während einer echten Übernahme aktiv) – der wahrscheinlichste Ausbreitungsweg (SMB von einem kompromittierten Windows-Rechner) ist damit für die Online-Backups weitgehend verschlossen.
- Die eigentlichen Backup-Skripte (bulinux.sh, bumo.sh, bunacht.sh, alle über bugem.sh) verwenden einen **Schutzdatei-Mechanismus**: Vor jedem Kopiervorgang wird eine Gruppe unauffälliger Referenzdateien (Schutzdatei\_bitte\_belassen.doc, Auch\_eine\_Schutzdatei\_bitte\_belassen.jpg, zusätzliche\_Schutzdatei\_bitte\_belassen.pdf) per SHA-256-Hash zwischen Quelle und Ziel verglichen; weicht auch nur eine ab, wird die Sicherung für das betroffene Verzeichnis **verweigert und eine Warnmail verschickt**, statt die gute Kopie stillschweigend zu überschreiben (relevant v. a. bei bumo.sh/bunacht.sh, die mit --delete arbeiten). Details siehe Abschnitt 6.
- gsbackup.sh (älterer, separater Mechanismus für CIFS-Ziele) hat diese Prüfung **nicht – geprüft am 12.7.2026: kein aktiver (nicht-auskommentierter) Cron-Aufruf auf**

**linux1, linux0 oder linux7 gefunden.** Der ursprüngliche Kritikpunkt (rsync ohne Versionierung, kein Schutz vor Überschreiben) ist damit gegenstandslos, solange das so bleibt.

---

## Teil A – Was schon jetzt bereitstehen sollte (Vorsorge)

### 1. Mindestens eine wirklich unveränderliche/getrennte Kopie (3-2-1-1-Regel)

- 3 Kopien der Daten, auf 2 verschiedenen Medientypen, 1 davon extern/offsite, 1 davon offline oder unveränderlich (immutable) bzw. air-gapped.
- **Korrektur (12.7.2026): Eine echte Offline-Kopie existiert bereits** und wurde bei der ursprünglichen Fassung dieses Dokuments übersehen: /DATA/down/mokopr.ps1 erstellt täglich von szn4 aus Kopien (Datenbanken, Patientendokumente, MariaDB-Dumps) auf zwei rotierende USB-Sticks (je 953 GB), die anschließend mit morueck.ps1 auf einen nicht mit der Praxis verbundenen Windows-Rechner zuhause übertragen werden. Das deckt “1 offline/air-gapped” der 3-2-1-1-Regel ab, inklusive Prüfung per Schutzdatei-Mechanismus (Größe/Datum/Inhalts-Hash) vor jeder Übertragung.
- Verbleibende, priorisierte Empfehlungen für die **Online**-Kopien auf linux0/linux7:
  - o **Bereits vorhanden, ungenutzt:** linux0:/DATA läuft bereits auf **Btrfs** (2,1 TB, Subvolume vorhanden) – Snapshots werden dort aber noch nicht gezogen (Snapper ist nur für die Systempartition / konfiguriert, nicht für /DATA). Nächster konkreter Schritt: eine Snapper-Konfiguration für /DATA auf linux0 anlegen und nach jedem bulinux.sh/bunacht.sh-Lauf einen read-only-Snapshot ziehen (z. B. 14 täglich + 8 wöchentlich) – kein Reformatieren nötig.
  - o linux7:/DATA und linux1:/DATA sind **ext4**, nicht snapshot-fähig – Umstellung auf Btrfs wäre eine größere Migration (7,2 TB) und dort niedriger priorisiert, solange linux0 den Snapshot-Schutz übernimmt.
  - o **Windows-Seite (noch offen, geplant):** Image-Backups (z. B. Macrium Reflect) der beiden Windows-2019-Server (Medical Office) sowie mindestens eines Praxis-PCs auf eine Reserveplatte, die nur zum Sichern angeschlossen wird (nicht dauerhaft verbunden), mit mindestens zwei Zielplatten im Wechsel. Noch nicht umgesetzt.

### 2. Backup-Architektur: “Pull” statt “Push”, getrennte Zugangsdaten

- Aktuell laufen die Sicherungen vom Produktivsystem aus (Push) mit denselben root-Rechten, die auch ein Angreifer bei Kompromittierung von linux1 hätte. Besser: Der Backup-Zielserver **zieht** sich die Daten (Pull) mit eigenen, eingeschränkten Zugangsdaten, sodass ein kompromittiertes linux1 das Backup-Ziel nicht direkt löschen/überschreiben kann.
- Mindestens: Backup-Ziele nicht mit denselben root/Admin-Credentials wie die Produktivsysteme erreichbar machen.

### 3. Netzsegmentierung

- linux0/linux7 sollten, solange sie nicht aktiv als Ersatz laufen, möglichst **nicht dauerhaft im selben Netzsegment mit vollem Schreibzugriff** auf dieselben Freigaben hängen.

Falls technisch/betrieblich schwierig: zumindest die Backup-Verzeichnisse (/DATA/DBBack, CIFS-Ziele) mit restriktiven Firewall-Regeln absichern, sodass nur die nötigen Dienste/Hosts zugreifen können.

#### 4. Zugänge härten

- SSH/root-Login: falls noch Passwort-Login aktiv, auf Key-basierte Authentifizierung umstellen, PermitRootLogin einschränken (mind. prohibit-password), fail2ban oder vergleichbares gegen Brute-Force.
- SMB/CIFS: SMBv1 deaktivieren, Freigabe-Rechte regelmäßig prüfen (wer darf wirklich schreiben?).
- Alle Fernzugänge (falls vorhanden: VPN, Remote-Support-Tools) mit Mehr-Faktor-Authentifizierung absichern.
- Windows-Arbeitsplätze in der Praxis sind der wahrscheinlichste Eintrittsweg (Phishing-Mail-Anhang, präpariertes Dokument) – dort Endpoint-Schutz/aktuelle Signaturen und eingeschränkte Benutzerrechte (kein Alltagsarbeiten mit Admin-Rechten) sind der wichtigste Hebel, den die Server-Seite nicht ersetzen kann.

#### 5. Patch-Management

- Betriebssystem und Dienste auf linux1/linux0/linux7 zeitnah patchen, insbesondere alles mit Netzwerk-Exposition (Samba, SSH, ggf. Webdienste). Ein fester, wiederkehrender Termin (z. B. monatlich) senkt das Risiko, dass eine bekannte Lücke offenbleibt.

#### 6. Monitoring/Alarmierung

**Stand 12.7.2026: vorhanden und getestet funktionsfähig.**

- **Mechanismus:** Vor jedem Backup-Kopiervorgang (bulinux.sh/bumo.sh/bunacht.sh auf der Bash-Seite, mokopr.ps1/morueck.ps1 auf der PowerShell/USB-Seite) wird eine Gruppe von drei bewusst unterschiedlich benannten und typisierten Referenzdateien (Schutzdatei\_bitte\_belassen.doc, Auch\_eine\_Schutzdatei\_bitte\_belassen.jpg, zusätzliche\_Schutzdatei\_bitte\_belassen.pdf) zwischen Quelle und Ziel per **SHA-256-Inhaltsvergleich** geprüft. Fehlt eine Datei auf der Quelle oder weicht ihr Inhalt ab, wird die Sicherung für das betroffene Verzeichnis **verweigert statt stillschweigend durchgeführt**, und eine Warnmail geht raus.
- **Mailversand war bis 12.7.2026 tatsächlich defekt** (beim Test aufgefallen, nicht vorher bemerkt) – gleich drei unabhängige Ursachen: (1) SELinux-Fehllabelung zweier Postfix-Lockdateien (behoben mit restorecon), (2) ungültige Absenderdomain (root@linux1.localdomain) führte zu hartem Bounce bei diabetologie@dachau-mail.de (behoben durch Umstellung auf Relay-Versand), (3) GMX lehnte direkten Versand wegen des dynamisch aussehenden PTR-Eintrags der IP grundsätzlich ab. **Fix:** Postfix versendet jetzt authentifiziert über den M-net-Smarthost (mail.mnet-online.de:587, SASL, STARTTLS; Zugangsdaten aus /root/mnetrc) mit per sender\_canonical\_maps korrigiertem Absender (gschade@dachau-mail.de). Erfolgreich getestet an alle drei konfigurierten Empfänger.
- **Empfänger** (SDMAILEMPF in bugem.sh): diabetologie@dachau-mail.de, gerald.schade@gmx.de, gerald.schade@gmx.de – bei Bedarf dort leicht erweiterbar.

- **Nebenbefund beim Testen, ebenfalls behoben – größer als zunächst gedacht:** Eine andere Mailkette (HylaFAX-Faxbenachrichtigungen an root@linux1/root@linux1.fritz.box) hing zunächst seit über 24h fest. Bei genauerem Hinsehen stellte sich heraus: **die LAN-interne Mailzustellung zwischen allen drei Servern war in beiden Richtungen kaputt**, auf linux7 sogar seit über zwei Monaten (226 hängende Nachrichten seit 8.5.2026, “No route to host”) – Ursache war die Kombination aus inet\_interfaces = loopback-only und einer Firewall ohne Port 25. Behoben auf linux1/linux0/linux7: Port 25 aus dem LAN (192.168.178.0/24) erlaubt, mydestination um eigenen Kurz-/FQDN-Namen ergänzt, transport\_maps so gesetzt, dass die jeweils anderen Server direkt per LAN-IP erreicht werden (sonst hätte alles unnötig über den externen M-net-Relay laufen wollen – lief dabei kurzzeitig sogar in eine Mail-Schleife “loops back to myself”, ebenfalls behoben). Alle sechs Richtungen (linux1 ↔ linux0, linux1 ↔ linux7, linux0 ↔ linux7) einzeln erfolgreich getestet. **los.sh** wurde entsprechend erweitert (Funktion postfix()), sodass ein neu aufgesetzter oder ersetzter Server das automatisch korrekt mitbekommt. Keine inhaltliche Verbindung zum Ransomware-Thema selbst, aber ein gutes Beispiel dafür, wie leicht ein Alarm-Mailversand – gerade zwischen den Reserve-Servern, die im Ernstfall die Identität übernehmen sollen – monatelang unbemerkt ins Leere laufen kann, wenn er nicht aktiv getestet wird.
- **Restrisiko/Ergänzung, die weiterhin sinnvoll bleibt:** ein Cron-Job, der stichprobenartig prüft, ob sich in kurzer Zeit ungewöhnlich viele Dateien in den Datenverzeichnissen ändern (typisches Massenverschlüsselungsmuster), unabhängig vom Schutzdatei-Mechanismus. Noch nicht umgesetzt.
- **Lehre daraus:** Alarmmechanismen mindestens 1×/Jahr aktiv testen (nicht nur “ist im Code vorhanden” annehmen) – siehe auch Punkt 7 (Recovery Day), sinnvollerweise gemeinsam mit einem Mail-Alarmtest.

## 7. Testweise Wiederherstellung (“Recovery Day”)

- Ein Backup, das nie zurückgespielt wurde, ist nur eine Vermutung. Mindestens 1–2× jährlich testen: Kann aus dem Backup-Bestand tatsächlich eine Datenbank/ein Verzeichnis vollständig und korrekt wiederhergestellt werden? Zeit dafür realistisch einplanen (nicht nur “Datei kopiert sich”, sondern “Praxissoftware startet damit korrekt”).

## 8. Notfallplan und -kontakte offline verfügbar halten

**Stand 12.7.2026: Kontaktliste unten mit recherchierten/bestätigten Daten gefüllt, weiterhin nicht ausgedruckt/extern hinterlegt (offen).**

- Diese Anleitung selbst, uebernahme.sh/rueckgabe.sh und die zugehörige Doku dürfen **nicht ausschließlich verschlüsselbar auf linux1/linux0/linux7 liegen**. Empfehlung: zusätzlich eine ausgedruckte oder auf einem USB-Stick/Cloud-Notiz außerhalb der Serverinfrastruktur abgelegte Kopie dieses Dokuments plus der wichtigsten Zugangsdaten/Notfallkontakte (analog zur bereits vorhandenen Anleitung\_MFA\_Notfall\_Uebernahme\_Rueckgabe-Logik, aber für den IT-technischen Ernstfall). **Noch nicht umgesetzt** – die Liste unten steht bisher nur hier im Dokument, also selbst wieder auf verschlüsselbaren Servern.
- **Praxis-Notfallnummern über die eigene (Gerald Schade, s. Anleitung\_MFA\_Notfall\_Uebernahme\_Rueckgabe.md) hinaus: keine vorhanden.**

- **Praxissoftware-Hersteller (Medical Office): redomed, Inh. Helmut Holz.**
  - Offizieller Kontakt (Homepage, Stand 12.7.2026): Martinsring 13, 94339 Leiblfring. Telefon/Support: **09427 / 90 19 10 0**, Fax: 09427 / 90 19 10 20, E-Mail: **support@redomed.de**. Bietet Fernwartung per TeamViewer an.
  - Geschäftsführer/Inhaber: Herr Holz, E-Mail: **helmut.holz@redomed.de** (Telefon geschäftlich identisch mit obiger Support-Nummer).
  - Mobil/privat: **+49 1511 6511336** – **kein offizieller Kontaktweg**, nur für den äußersten Notfall (z. B. wenn der reguläre Support-Kanal wegen des Vorfalls selbst nicht erreichbar ist), nicht routinemäßig nutzen.
- **IT-Forensik/Incident-Response-Dienstleister:** recherchiert am 12.7.2026 über die offizielle BSI-Liste qualifizierter APT-Response-Dienstleister (Stand 01.06.2026, staatlich geprüfter Qualitätsstandard). **Auswahl bewusst offen gelassen** – Empfehlung: 1–2 davon vorab unverbindlich kontaktieren, um Eindruck/Konditionen zu bekommen, bevor man sich festlegt.
  - **Corporate Trust Business Risk & Crisis Management GmbH** (München) – Tel. +49 89 599 88 75 80, info@corporate-trust.de
  - **HvS-Consulting GmbH** (München) – Tel. +49 89 890 636 261, incidentresponse@hvs-consulting.de
  - **msg systems ag – security advisors** (Ismaning/München) – 24/7-Hotline +49 89 413242320, dfir@msg.group (größte/etablierteste der vier, ggf. eher auf größere Mandanten ausgerichtet)
  - **intersoft consulting services AG** (Hamburg, nicht Bayern) – 24/7-Hotline +49 180 622 124 6, it-forensik@intersoft-consulting.de – bietet zusätzlich Datenschutzrecht/DSGVO-Beratung aus einer Hand an
- **Cyber-Versicherung:** aktuell **bewusst nicht** abgeschlossen (s. Punkt 9).
- **Zentrale Ansprechstelle Cybercrime (ZAC) Bayern** beim Bayerischen Landeskriminalamt – Erstanlaufstelle der Polizei für Unternehmen/Praxen bei Cybercrime-Vorfällen, auch beratend vor einem Vorfall:
  - Online-Meldung: <https://www.zac-formular.polizei.bayern.de/>
  - Telefon: **+49 89 1212-3300**, E-Mail: **zac@polizei.bayern.de**
  - Adresse: Maillingerstraße 15, 80636 München
- **Zuständige Datenschutzbehörde:** s. Punkt 10 (BayLDA).
- **Ärztekammer/KV** – zwei unterschiedliche Stellen, je nach Situation:
  - **Ärztekammer** (Standesrecht/Schweigepflicht): vor allem relevant, wenn Hinweise auf tatsächlichen **Datenabfluss** vorliegen (nicht nur Verschlüsselung vor Ort) – berührt dann ggf. § 203 StGB. Bayerische Landesärztekammer, München, allgemeine Beratung auch präventiv möglich.
  - **KV (Kassenärztliche Vereinigung Bayerns):** relevant, wenn Abrechnung/Praxisbetrieb durch den Vorfall gestört ist (Fristen, Ersatzverfahren) – kein Bezug zur Schweigepflicht.

## 9. Cyber-Versicherung prüfen

**Entscheidung (Stand 12.7.2026): aktuell bewusst nicht abgeschlossen.** Falls sich das später ändert: für eine Arztpraxis mit Patientendaten grundsätzlich sinnvoll, deckt oft auch Forensik-Dienstleister und Betriebsunterbrechung ab – dann vorab prüfen, welche Auflagen die Police an die IT-Sicherheit stellt (sonst im Schadensfall Deckungslücke).

## 10. Rechtliche Vorbereitung (Gesundheitsdaten!)

- Da Patientendaten betroffen sind (Art. 9 DSGVO – besondere Kategorien), ist ein Ransomware-Vorfall mit Zugriff/Verschlüsselung dieser Daten in aller Regel eine **meldepflichtige Datenschutzverletzung** (Art. 33 DSGVO, 72-Stunden-Frist ab Kenntnis) und ggf. Informationspflicht gegenüber Betroffenen (Art. 34 DSGVO).
  - **Zuständige Behörde (Sitz Dachau, Bayern): Bayerisches Landesamt für Datenschutzaufsicht (BayLDA)** – zuständig für nicht-öffentliche Stellen (Arztpraxen, Unternehmen, Selbstständige), recherchiert und bestätigt am 12.7.2026:
    - **Online-Meldeformular (empfohlen, da schnellere Bearbeitung):**  
<https://www.lda.bayern.de/de/datenpanne.html> – liefert nach Absenden sofort eine eigene Vorgangs-ID mit Zeitstempel als Nachweis der 72h-Frist; unterstützt auch Folgemeldungen zum selben Vorgang.
    - Telefon: **+49 981 180093-0** (Mo–Fr 8:00–12:00 Uhr), Fax: +49 981 180093-800
    - Adresse: Promenade 18, 91522 Ansbach; E-Mail: [poststelle@lda.bayern.de](mailto:poststelle@lda.bayern.de) (nur PDF-Anhänge)
    - Für technische/kriminalpolizeiliche Seite parallel **ZAC Bayern** kontaktieren (s. Punkt 8) – das BayLDA selbst verweist bei Cybercrime-Fällen auch dorthin.
- 

## Teil B – Vorgehen im akuten Ransomware-Fall

### Schritt 1: Isolieren, bevor irgendetwas anderes passiert

- Betroffene(s) System(e) **sofort vom Netz trennen** (Netzwerkkabel ziehen bzw. Netzwerk-Interface deaktivieren) – nicht sofort ausschalten, wenn vermeidbar (laufende Verschlüsselung stoppt durch Netztrennung oft schon, und der Systemzustand bleibt für eine spätere forensische Einschätzung erhalten).
- **Alle anderen Systeme im selben Netz prüfen und vorsorglich ebenfalls trennen**, solange unklar ist, wie weit sich der Trojaner schon ausgebreitet hat – ausdrücklich auch linux0/linux7, falls sie zu dem Zeitpunkt im Netz eingebunden waren (siehe Hinweis oben: Failover-Server sind kein automatischer Schutz).
- **Auf keinen Fall** jetzt ein Backup-Medium anschließen, das nicht sicher schreibgeschützt ist – sonst droht, dass auch die letzte gute Kopie überschrieben oder mitverschlüsselt wird.

### Schritt 2: Beweise sichern, bevor aufgeräumt wird

- Erpresserbotschaft (Screenshot/Foto), betroffene Dateieindungen, ungefähre Uhrzeit des ersten Auffallens, verdächtige E-Mails/Anhänge der letzten Tage notieren.

- Relevante Logs sichern, bevor sie rotiert werden (/var/log/rsync.log, gsbackup.prot/gsbackupfehler.prot, System-/Auth-Logs, Cron-Logs).
- Das alles wird für Anzeige, Versicherung und eine mögliche Forensik gebraucht.

### Schritt 3: Nicht zahlen, nicht selbst experimentieren

- Von offizieller Seite (BSI u. a.) wird von Lösegeldzahlungen abgeraten: keine Garantie auf Entschlüsselung, finanziert weitere Kriminalität, macht als “zahlender Kunde” ggf. erneut zum Ziel. Die endgültige Entscheidung liegt selbstverständlich bei euch, aber sie sollte nicht spontan unter Druck getroffen werden.
- Vor jedem eigenen Entschlüsselungsversuch mit Tools aus dem Netz: Vorsicht vor Falsch-Tools, die zusätzlichen Schaden anrichten. Bekannte, saubere Entschlüsselungstools (falls die Ransomware-Familie bereits geknackt ist) finden sich z. B. beim Projekt “No More Ransom” (nomoreransom.org) – dort zuerst die erkannte Ransomware-Variante identifizieren lassen.

### Schritt 4: Experten hinzuziehen

- Spätestens jetzt IT-Forensik/Incident-Response-Dienstleister kontaktieren (idealerweise vorab schon bekannt, siehe Teil A.8) bzw. über die Cyber-Versicherung vermitteln lassen. Bei einer Arztpraxis mit Patientendaten ist “selber schnell reparieren” wegen der rechtlichen Lage riskanter als bei einem reinen Hobby-Server.

### Schritt 5: Melden (rechtliche Pflichten nicht vergessen)

- **BayLDA:** binnen 72 Stunden nach Kenntnis melden (Art. 33 DSGVO), da Gesundheitsdaten wahrscheinlich betroffen sind – auch wenn zu diesem Zeitpunkt noch nicht alle Details geklärt sind (Nachmeldung ist möglich). Online-Formular: <https://www.lda.bayern.de/de/datenpanne.html> (liefert sofort eine Vorgangs-ID als Fristnachweis), telefonisch +49 981 180093-0 (Mo–Fr 8–12 Uhr). Details s. Teil A, Punkt 10.
- **Betroffene Patienten:** prüfen, ob Informationspflicht nach Art. 34 DSGVO greift (hohes Risiko für Rechte/Freiheiten der Betroffenen – bei Gesundheitsdaten im Zweifel eher ja).
- **ZAC Bayern (Polizei):** Zentrale Ansprechstelle Cybercrime beim Bayerischen LKA, <https://www.zac-formular.polizei.bayern.de/>, Tel. +49 89 1212-3300. Details s. Teil A, Punkt 8.
- **BSI:** freiwillige Meldung möglich und sinnvoll (Lagebild, ggf. Unterstützung).
- **Ärztekammer:** falls Hinweise auf tatsächlichen Datenabfluss vorliegen (nicht nur Verschlüsselung) – berührt dann ggf. die Schweigepflicht (§ 203 StGB). **KV Bayerns:** falls Abrechnung/Praxisbetrieb durch den Vorfall gestört ist (Fristen, Ersatzverfahren) – anderer Grund, andere Stelle, s. Teil A, Punkt 8.

### Schritt 6: Wiederherstellung – sauber statt schnell

- **Nicht einfach das verschlüsselte System “bereinigen” und weiterlaufen lassen.** Empfehlung: betroffene(s) System(e) komplett neu aufsetzen (Betriebssystem-Neuinstallation), nicht nur die sichtbare Schadsoftware entfernen – Backdoors/Persistenzmechanismen bleiben sonst oft unentdeckt zurück.



- Daten **nur aus einer nachweislich sauberen Kopie** wiederherstellen, die sicher **vor** dem Infektionszeitpunkt liegt. Genau hier zeigt sich, warum Teil A wichtig ist: ohne unveränderliche/versionierte Kopie lässt sich oft schwer beweisen, dass ein Backup wirklich “sauber” ist.
- Die bestehende linux0/linux7-Übernahme-Logik (uebernahme.sh) **nicht ungeprüft** als “sauberen Ersatz” nutzen, wenn unklar ist, ob diese Systeme zum Infektionszeitpunkt im Netz erreichbar und damit potenziell auch betroffen waren. Erst prüfen (Neuinstallation im Zweifel auch hier), dann übernehmen.
- **Alle Zugangsdaten wechseln** – root-Passwörter, SSH-Keys, CIFS/Samba-Konten, WLAN, Fernzugänge, ggf. auch Konten der Praxissoftware selbst. Ein Angreifer, der einmal drin war, hat evtl. Zugangsdaten mitgelesen.
- Erst nach Schließen der bekannten Einfallstür (Patch, geändertes Passwort, entferntes offenes Protokoll o. Ä.) wieder ans Netz gehen.

### Schritt 7: Nachbereitung

- Kurzer, schriftlicher Rückblick: Wie kam der Trojaner rein, was hat wie lange gedauert, was hat gut/schlecht funktioniert? Diese Anleitung danach entsprechend aktualisieren.
  - Praxisteam kurz sensibilisieren (v. a. Phishing-Erkennung), da der Eintrittsweg sehr häufig über einen Windows-Arbeitsplatz läuft, nicht über den Server direkt.
- 

### Kurz-Checkliste für den Ernstfall (zum schnellen Nachschlagen)

1. Netz trennen (betroffenes System + vorsorglich linux0/linux7).
2. Kein Backup-Medium anschließen, bevor Lage klar ist.
3. Beweise sichern (Screenshots, Logs, Dateiliste).
4. Nicht zahlen, keine Drittanbieter-Tools ungeprüft ausführen.
5. Forensik-/IR-Dienstleister + Versicherung kontaktieren.
6. Meldung: BayLDA (72h, [lda.bayern.de/de/datenpanne.html](https://lda.bayern.de/de/datenpanne.html)), ggf. Patienten, ZAC Bayern (Polizei), ggf. BSI/Ärztchammer/KV.
7. Sauber neu aufsetzen statt nur bereinigen, nur aus nachweislich sauberem Backup wiederherstellen.
8. Alle Zugangsdaten wechseln, Einfallstor schließen, erst dann wieder ans Netz.
9. Nachbereitung + dieses Dokument aktualisieren.